

Oncology Virtual Expert case study

Software Safety & Risk Management

From a working model to a compliant medical device - A regulatory perspective for medical device software

Regulatory perspective • Cercare Medical Oncology Virtual Expert as example

You can build it. Can you deploy it?

What you've built

- Agentic-coded GUI to inspect oncology MRI cases
- FLAIR-threshold classifier
- 2D U-net segmentation
- Metrics that look good on your test split

What a hospital (and a regulator) needs

- A defined intended purpose and a device class
- Evidence the risks are identified and controlled
- A lifecycle you can audit end-to-end (traceability)
- Proof it does what you claim — verification & validation
- A plan for what happens after release

The gap between these two columns is what this session is about.

By the end you will be able to...

01

Decide if your software is a medical device and classify it

Apply the intended-purpose test and MDCG/IMDRF logic and classify under MDR Rule 11

02

Understand the importance of data governance

For AI software the dataset is part of the evidence chain

03

Understand the concept of risk analysis

Hazard → hazardous situation → harm, with severity × probability

04

Understand the structure of a compliant lifecycle

Use the V-model and key elements of V&V, incl. clinical considerations

05

Read a real QMS

Recognise the example artefacts Cercare produces for each release

06

Apply it to your viewer/classifier

Classify your own tool and produce a mini risk file

AI inside the device vs AI used to create it

AI used during development

- Examples: coding assistance, documentation drafting, test suggestions, literature triage or internal review support.
- Regulatory issue: control, review, verification, authorship and accountability remain with the manufacturer.
- Treat AI output like any other development input: review, verify and document where relevant.

AI incorporated into the device

- OVE's AI output is part of the medical device output.
- The model must be validated as part of the device, not as a standalone research artifact.
- Evidence must cover data, model, integration, workflow and post-market monitoring.
- This presentation focuses primarily on AI incorporated into the device.

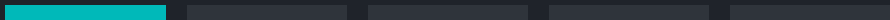
Both debates matter — but only the AI inside the device has to be validated as part of the device.

Part 1

Framing the device

Qualification & classification - and why the answer starts with the intended purpose, not the algorithm.

01



When does your code become a medical device?

MDCG 2019-11 Rev. 1 asks four questions, in order.

1

Is it software?

Instructions that turn input data into output data.

2

Does it drive or influence another device?

Then it takes that device's class — implementing rule 3.3.

3

More than storage, search or lossless compression?

It calculates. Lossy compression already counts as acting on data.

4

For the benefit of individual patients?

Not population-level, not epidemiological. Diagnosis, prevention, monitoring, prediction, treatment for an actual individual patient.

Three things that catch people out

The claim is the trigger

Research use only — until someone writes a clinical claim. Marketing material, conference presentations, website — all communication about the device counts!

Modularity is decisive

Viewer and U-net can be separate modules, if the architecture really separates them.

Same goal, different answer

A FLAIR overlay may not qualify. A U-net that labels the lesion does.

→ **Medical Device Software (MDSW)** = SaMD to IMDRF and the FDA

MDCG 2019-11 Rev. 1, June 2025 — Figure 1.

Which standards actually protect you?

The MDR 2017/745 states the obligation. Only a harmonised standard gives presumption of conformity.

HARMONISED — presumption of conformity

EN ISO 14971:2019/A11:2021

Risk management

EN ISO 13485:2016

Quality management system

STATE OF THE ART — no presumption

IEC 62304:2006+A1:2015 Software life cycle

IEC 82304-1:2016 Health software product safety

IEC 62366-1:2015+A1:2020 Usability engineering

IEC 81001-5-1:2021 Security in the life cycle

ISO/TS 24971-2:2026 ISO 14971 for machine learning — new

AAMI TIR34971:2023 Its predecessor

Not harmonised is not optional. MDR Annex I requires the generally acknowledged state of the art — every notified body reads IEC 62304 as exactly that. You comply; you just carry the burden of showing it.

The rule that classifies almost all diagnostic AI – rule 11

Software intended to provide information which is used to take decisions with diagnosis or therapeutic purposes is classified as class IIa, except if such decisions have an impact that may cause:

— death or an irreversible deterioration of a person's state of health, in which case it is in class III; or

— a serious deterioration of a person's state of health or a surgical intervention, in which case it is classified as class IIb.

MDR Annex VIII, Rule 11, first three paragraphs — verbatim. Monitoring software and “all other software” follow in paragraphs 4 and 5.

Class IIa

Information for a diagnostic or therapeutic decision

Class IIb

Serious deterioration, or surgery

Class III

Death or irreversible deterioration

All classification rules must be reviewed!

Even if rule 11 is the “go-to” for Medical Device Software, all classification rules must be carefully reviewed

Rule 3.3

Software driving another device takes that device's class.

Rule 3.5

The strictest applicable sub-rule always wins — one function can set the class of the whole product.

Class ≥ IIa means a notified body!

Which is also the AI Act's high-risk gate, from 2 August 2028.

How IIa, IIb and III are decided

Healthcare situation × significance of the information. MDR class, with the IMDRF category in brackets.

HEALTHCARE SITUATION ↓	SIGNIFICANCE OF INFORMATION →		
	Inform management	Drive management	Treat or diagnose
Critical	IIa II.i	IIb III.i	III IV.i
Serious	IIa I.ii	IIa II.ii	IIb III.ii
Non-serious	IIa I.i	IIa I.iii	IIa II.iii

Three caveats

- Every cell is at least IIa. The table excludes Class I entirely.
- It maps sub-rule 11a only — monitoring and “all other software” sit outside it.
- It is guidance by analogy. Rule 11's own escalation wording is the legal test! Argue carefully.

Oncology Virtual Expert: serious situation × drives clinical management → Class IIa (II.ii in the chart)

Where would “flags suspected large-vessel occlusion in acute stroke triage” land, and why?

The OVE processing pipeline, end to end

The running example used throughout the presentation



OVE as an example

- Real intended purpose
- Mixes AI-generated outputs with non-AI longitudinal and VOI functions.
- Raises annotation, ground truth, bias and change-control questions.

Regulatory anchors

- Decision support for trained professionals — not autonomous diagnosis.
- Backed by requirements, risk, V&V, clinical and cybersecurity evidence – full QMS

OVE is a module inside CMN — the regulated device is the whole processing chain, *not just the neural network*.

Intended purpose is the regulatory anchor

Every downstream conclusion depends on this wording

Questions to consider

- Who uses the device and with what expertise?
- Which patients and clinical situations are in scope?
- Which images and preprocessing environment are required?
- What outputs are provided, and how are they used?
- Does the output inform, drive, diagnose, treat or automate a decision?

OVE examples

- Decision-support cerebral image processing and delineation for neuro-oncology.
- Works with structural, perfusion and diffusion MRI and CMN / Capillary Function output maps.
- Supports management rather than directly diagnosing or treating.
- Any claim expansion would affect classification, evidence and risk controls.

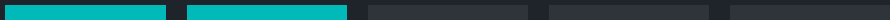
Change one word in the intended purpose and you potentially change the classification, the evidence required and the risks that must be controlled.

Part 2

Data and ground truth

For AI software the dataset is part of the evidence chain

02



Data provenance is a safety issue

For AI SaMD, data is part of the evidence chain

Questions regulators will ask

- Where did the data come from, and under which legal or ethical approvals?
- Which clinics, scanners, protocols, sites and patient groups are represented?
- Was data used for training, tuning, independent testing or clinical evidence?
- Can inclusion/exclusion, preprocessing and annotation history be reconstructed?
- Does the dataset match the intended-use population and clinical workflow?

OVE examples

- Structural MRI inputs have defined sequence and preprocessing requirements.
- Data details and demographic distributions are handled in dynamically generated model reports.
- FDA comparison study provides patient-material characteristics for 100 retrospective subjects.
- Clinical evaluation relies on structured literature and device-specific evidence.

If you cannot reconstruct where the data came from, you cannot defend what the model learned from it.

Ground truth is not automatically truth

Annotated oncology data creates its own regulatory burden

Annotation controls to consider

- Who annotated: radiologist, neuroradiologist, oncologist, technician or mixed panel?
- How many readers, and what expertise level?
- Which annotation guideline, and was it predefined?
- Was there blinding, consensus, adjudication and disagreement handling?
- Can the annotation process be reconstructed after release?

OVE examples

- Neural networks are trained and validated on manual expert segmentations.
- Network quality is bounded by annotation quality.
- This is directly relevant to edema, enhancing tissue and necrosis labels.
- Label quality links to performance claims, risk analysis and clinical evidence.

The network can never be more accurate than the experts who drew the labels it learned from.

Representativeness, bias and data adequacy

Sample size is only one dimension of dataset quality

Bias / coverage dimensions

- Tumor type, size, stage, treatment state and morphology.
- Scanner vendor, model, magnetic field strength and protocol variation.
- Geography, clinical site, demographics and referral patterns.
- Preprocessing failures, missing sequences and image artifacts.
- Rare but high-risk edge cases.

OVE examples

- Data adequacy is argued using state-of-the-art comparison and performance plateau.
- The FDA comparison report exposes real cohort characteristics and scanner distribution.

The useful question is whether the dataset supports the intended purpose — not whether the sample size sounds impressive.

The validated domain starts before the AI model

Input-domain control is an AI safety control



What must be true at the input

- All required sequences present and correctly identified.
- Preprocessing completes without failure or gross artefact.
- Image format and geometry match what the network was trained on.

When inputs fall outside the domain

- A missing sequence or failed brain extraction can still produce output.
- Unfamiliar scanners or protocols shift the input distribution.
- The result may be plausible-looking but wrong — and unflagged.

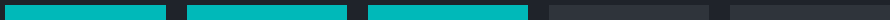
Unsupported inputs are not a usability annoyance — they are a safety issue, and input-domain control is a risk control.

Part 3

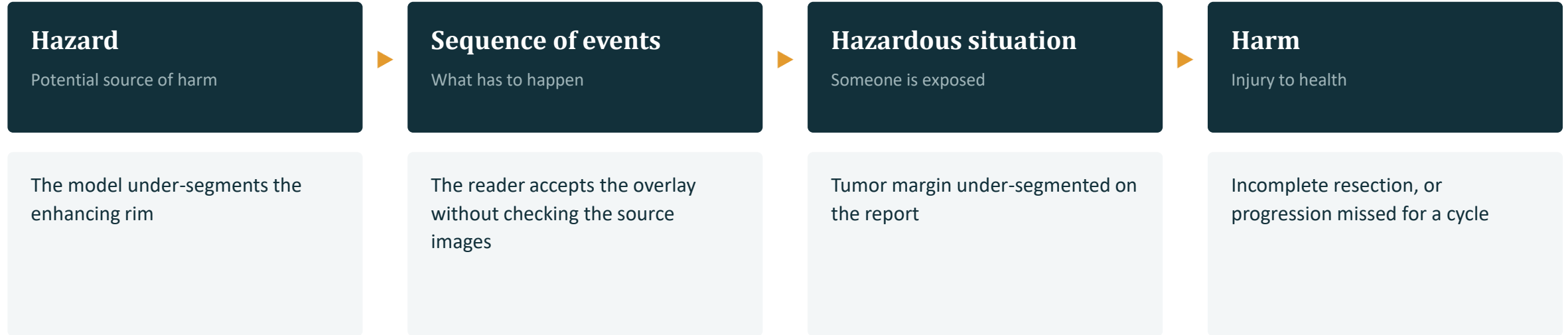
Risk management

ISO 14971 — the discipline of finding harm before patients do

03



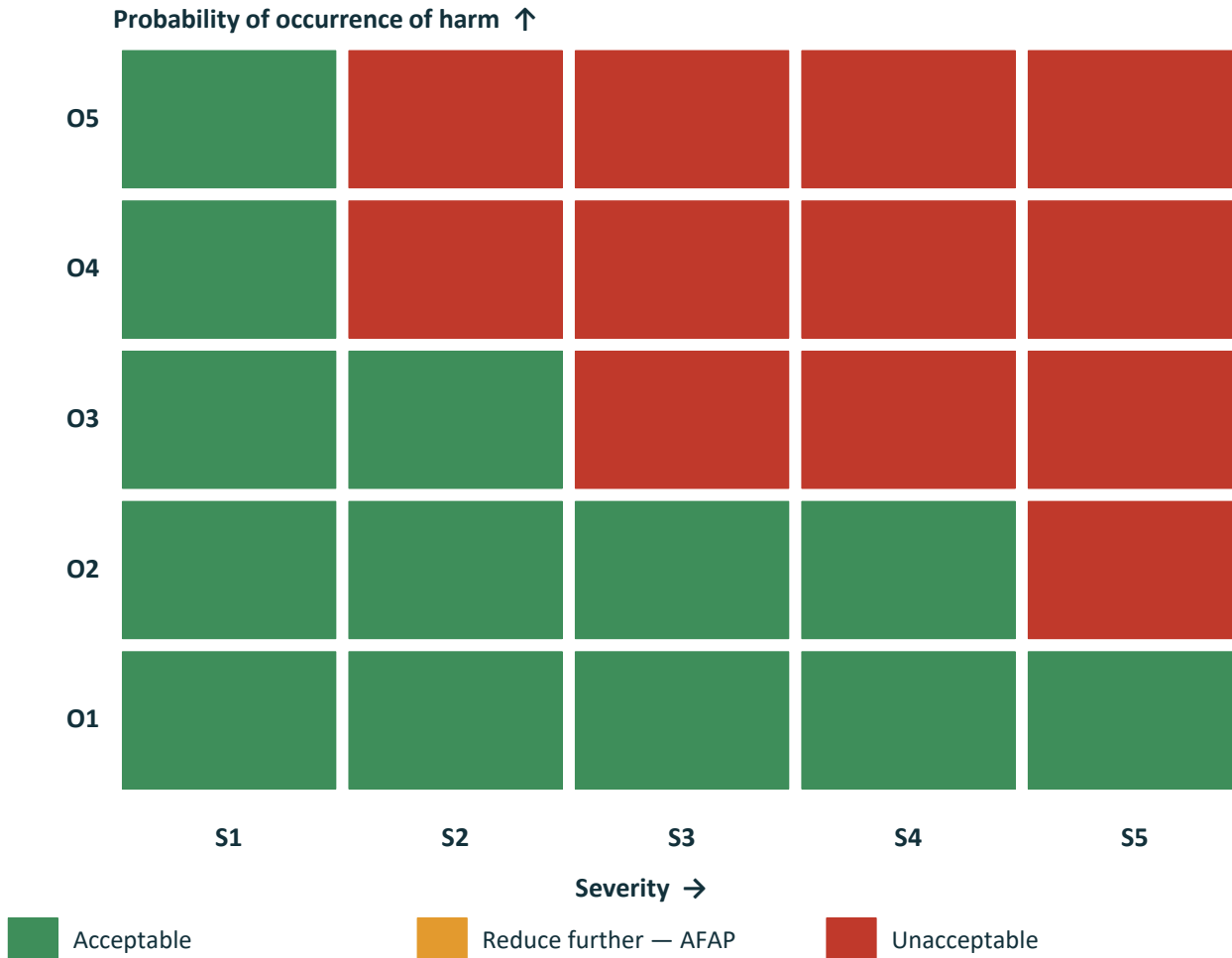
Hazard → hazardous situation → harm



Break any link and you have a risk control. Engineers reflexively attack the first box — make the model better. ISO 14971 says you may equally break the sequence, remove the exposure, or reduce the severity.

“Risk: the model is inaccurate” is not a risk. It is a hazard, and it cannot be estimated or controlled as written.

Severity × probability — and what is actually required



What ISO 14971 requires

- A top-management policy for risk acceptability
- Criteria written into the risk management plan
- Not a matrix, not a 5×5, not any number of levels – but it is considered good practice
- Cercare example scales:
 - S1 Negligible
 - S2 Minor injury
 - S3 Moderate
 - S4 Serious (reversible)
 - S5 Death / irreversible
 - O1 <1/1,000,000
 - O3 <1/1,000
 - O5 >1/10

This matrix is a convention. No standard requires it.

You cannot put a probability on a software failure

“When the probability of occurrence of harm cannot be estimated, it is necessary to evaluate the risk on the basis of the severity of harm alone.”

ISO/TR 24971:2020, cl. 5.5.3 — which names software failure as an example where probability cannot be estimated.

1

Software faults are systematic

A bridge fails stochastically. Code fails deterministically, every time the triggering input arrives. There is no failure rate for the y-axis of the previous slide.

2

Severity carries it — harm stays preventable

Assume the fault occurs. The harm is not automatic: the step from hazardous situation to harm is still open, and that is where risk controls act.

3

And rigour substitutes for probability

The less you can measure, the more process you must buy — and the more severe the harm, the more of it. That argument is what IEC 62304 implements.

IEC 62304 cl. 4.3: the 100 % assumption is **for software safety classification only**. In device-level risk analysis the probability of occurrence is likewise set to 100 % — but the harm remains preventable, so the risk turns on severity and on the effectiveness of the risk controls.

Design it out, guard it, then warn — in that order

1 • Inherently safe design

Constrain the output. Refuse input outside the validated envelope.

2 • Protective measures in the device

Out-of-distribution (OOD) detection, confidence gating, mandatory source-image display, audit log.

3 • Information for safety

IFU warnings, labelling, training. The weakest control there is with very limited potential for reducing risk

Then, for every control

- Verify it works, not just that it exists
- Re-estimate the residual risk
- Evaluate benefit-risk for what remains
- Check it created no new hazard
- Judge the overall residual risk, then tell users

MDR Annex I §4 and ISO 14971 cl. 7.1 — same three options, same binding order.

“We'll put it in the manual.” No rule forbids it in so many words. The prohibition is derived: the phrase “in the following order of priority” is binding, and §2 sets the target at as far as possible — so you may not skip option (a) while (a) is feasible.

Human oversight must actually work

“The clinician checks it” is not automatically a sufficient risk control

Oversight questions

- Can the user see inputs and outputs clearly enough to detect errors?
- Can segmentation be edited or rejected before it affects the workflow?
- Does the UI expose limitations or encourage automation bias?
- Is the user trained, and does the IFU explain correct interpretation?
- Is there realistic time for meaningful review in the workflow?

OVE examples

- OVE is decision support and output is intended as additional image series for clinicians.
- Validation scenarios include editable glioma segmentations and longitudinal results.
- Requirements, design and test documents include interaction and UI elements.
- Device limitations acknowledge discrepancies between manual and automated delineations.

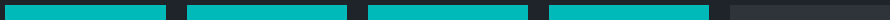
“The clinician checks it” is only a risk control if the workflow gives them the means — and the time — to catch the error.

Part 4

Lifecycle, evidence and change

If you cannot buy confidence with statistics, you buy it with process and evidence.

04



Traceability and V&V across the full pipeline

SPECIFY

Customer need

Follow-up and progression assessment in neuro-oncology

System requirements

Functional, performance and risk-control requirements

Design and architecture

Software design specification, units and interfaces

Verification: does it meet the specification?

Validation: does it meet the clinical need, with real users, on patients and scanners it has never seen?

VERIFY AND VALIDATE

Validation and clinical evaluation

Glioma delineation, longitudinal results, VOI, editable segmentations

System verification

Requirement-driven; Four-Eyes reviewed pull requests

Unit and integration testing

Automated through Jenkins and Pytest

“Validation” is a trap in machine learning. Your validation split is a tuning set. In a technical file, validation means clinical fitness for purpose. Say tuning split and external test set instead.

traceability links

Training ≠ validation ≠ clinical evaluation

Development evidence

- Training data: the model learns.
- Tuning / validation data: development choices are made.
- Independent test data: performance is measured.
- Software verification: requirements and design outputs are checked.
- Validation: the final device is tested for intended use.

Regulatory interpretation

- Clinical evaluation interprets all evidence against the intended purpose.
- Training performance is not clinical evidence for the final device by itself.
- Dataset leakage or weak independence can invalidate apparent performance.
- Evidence must support safety, performance, benefit-risk and claims.

Training performance is not clinical evidence — three different questions need three independent datasets.

Clinical evidence stands on three legs

MDCG 2020-1 requires all three. A Dice score answers part of one of them.

1

Valid clinical association

Is the output linked to the clinical condition, and is that link accepted by the medical community or in the literature?

Is enhancing-volume change a recognised marker of progression here? A literature question, not a coding question — and the leg most often assumed.

2

Technical performance

Does the software reliably produce the intended output from the input data?

Dice 0.88 oedema, 0.87 enhancing, 0.76 necrosis, with thresholds tied to the clinical evaluation. Where nearly all AI papers live — and stop.

3

Clinical performance

Does it yield clinically relevant output, achieved by real users, in the intended workflow?

Does the tool change what the MDT concludes — and change it correctly? Needs readers, a workflow and a comparator.

Cumulative, not alternative: technical performance without a valid clinical association evidences nothing.

Performance metrics can mislead

Algorithm metrics must be translated into clinical relevance

Metric questions to consider

- Which metric maps to clinical risk: Dice, volume error, sensitivity or progression flag?
- Does the same score have different consequences depending on lesion location or tissue class?
- Are edema, enhancing tissue and necrosis equally important for the supported decision?
- Are acceptance criteria clinically meaningful and predefined?
- Are subgroup and edge-case failures hidden by average performance?

OVE examples

- FDA comparison study uses Dice, Pearson correlation and Bland–Altman bias / limits of agreement.
- Acceptance is framed using non-inferiority relative to predicate and clinical acceptability versus manual segmentation.
- CER supports performance claims through literature and device-specific results.
- High average Dice does not prove clinically relevant enhancing tissue is never missed.

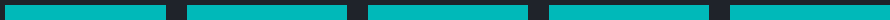
A high average Dice score does not prove that clinically relevant enhancing tissue is never missed.

Part 5

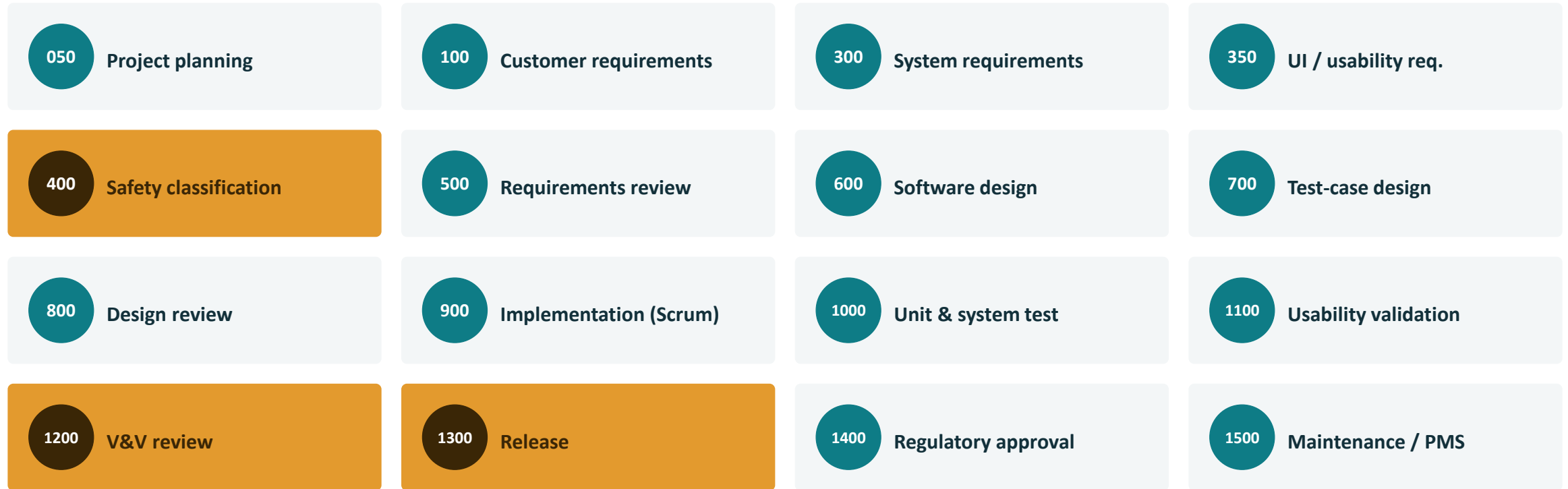
Inside a real QMS

What all of this looks like when an auditor is sitting in the room.

05



One company's pipeline, 050 to 1500



A V-model backbone with Scrum inside step 900. Small releases skip steps in proportion to the changes

Ordinary tools, wired so the process is enforced. Jira · Git and Bitbucket · Jenkins · DVC for datasets and models · SharePoint for records. And four-eyes on every controlled change.

All steps have defined responsibilities and deliverables that forms the complete documentation package

SOUP & the Software Bill of Materials

“Software item that is already developed and generally available and that has not been developed for the purpose of being incorporated into the medical device.”

SOUP — IEC 62304, cl. 3.29

What IEC 62304 makes you do

- Specify what you need from the item, and what it needs to run
- Treat SOUP failure as a cause of a hazardous situation
- Evaluate the supplier's anomaly list for the exact version you ship
- Inventory every item, libraries included — at every safety class

Your weights are SOUP too. PyTorch, MONAI, the DICOM parser — and the pretrained backbone and the framework that produced your checkpoint.

The SBOM ties it together

- A complete inventory of every component — your code, third-party libraries, and SOUP — so that when a vulnerability lands in a dependency, you can answer in minutes: “do we ship that, in which released version, and what's the patient impact?” Cercare added an explicit SBOM requirement to 9190 in 2026.

Oncology Virtual Expert — the whole picture

What it is

A module in Cercare Medical Neurosuite. It segments necrotic, T1-enhancing and oedematous tissue from structural, perfusion and diffusion MRI, and aggregates over time to support neuro-oncology management.

It supports the diagnosis. It does not make it — and that sentence is the classification argument.

MDR

Class IIa

Rule 11

IEC 62304

Class B

Non-serious injury

FDA

Moderate

Level of concern

The technical file it ships with

Roughly 35 controlled deliverables, each version-controlled and reviewed under four-eyes. Key deliverables

- | | | |
|----------------------------------|-----------------------------|--------------------------|
| ▪ MDR Classification | ▪ System Architecture Spec. | ▪ Instructions for Use |
| ▪ Intended Use | ▪ Software Design Spec. | ▪ Traceability Analysis |
| ▪ Customer Req. Spec. | ▪ Cybersecurity Analysis | ▪ Device Labelling |
| ▪ System Req. Spec. | ▪ Test Cases | ▪ Risk Management Report |
| ▪ Risk Management Plan | ▪ Verification Test Report | ▪ Unresolved Anomalies |
| ▪ Risk Analysis | ▪ Validation Test Plan | ▪ Revision Level History |
| ▪ Software Safety Classification | ▪ Validation Test Report | ▪ PMS / PMCF Plan |

Read the list as an example map of required deliverables. Nothing on it exists because someone enjoys documents.

What a regulatory body will often challenge

1

Is the intended purpose identical in every document — device description, IFU, classification, Declaration of Conformity, clinical evaluation and marketing material?

2

Why Class IIa, and why not IIb or III? Which paragraph of Rule 11, and which implementing rule did you rely on?

3

Where exactly is the AI, and which non-AI functions depend on its output?

4

Who annotated the training data, under which guideline, and how was disagreement adjudicated?

5

How independent and how representative are the training, tuning, test and clinical-evidence datasets?

6

What happens when the segmentation is wrong — can the user detect it and correct it in the real workflow?

7

How are model changes controlled after release, and what would trigger a new conformity assessment?

Six sentences that should survive the slides

- 1 The claim makes the device. Intended purpose, not the algorithm, decides qualification and classification.
- 2 Rule 11 puts almost all diagnostic AI at IIa or higher
- 3 You cannot put a probability on a software failure. Evaluate on severity; buy confidence with process -> Process scales to risk!
- 4 Design it out, guard it, then warn. The order is binding.
- 5 Your model and weights are SOUP, and retraining is a change to a certified device. Version everything; keep an SBOM.
- 6 Compliance is ordinary tools wired for traceability — as Cercare shows with Git, Jira, Jenkins & DVC.

Part 6

Your turn

Put your oncology viewer/classifier through the same lens

06



Your viewer/classifier, through the regulatory lens

Intended purpose	Write one sentence. “Displays MRI” vs “flags suspected tumour” changes everything.
Qualification	Does it act on data for a patient's benefit? FLAIR-threshold overlay may be borderline; a U-net that labels lesions is MDSW.
Classification	Rule 11: informs a diagnostic decision → at least IIa. Would a wrong output risk serious harm?
62304 class	Could a failure injure someone? Then Class B minimum — plan design & unit rigour accordingly.
V & V	Verify the pipeline; validate on unseen patients from a different scanner / site.
SOUP / SBOM	PyTorch, MONAI, the pretrained backbone, the DICOM reader — inventory and pin them.

Six hazards your U-net adds that a threshold does not

Each one is a hazard in the ISO 14971 sense. So each one needs a control

1 Dataset shift

Scanner, protocol or population drifts from training.

Example Control: Gate on acquisition metadata; monitor inputs.

2 Opaque failure

Confidently wrong, with no low-confidence or out-of-distribution signal to warn the reader

Example Control: OOD detection and a refuse-to-report path.

3 Automation bias

A plausible overlay stops the reader looking.

Example Control: Interaction design; summative evaluation.

4 Poor generalization

Great on your held-out split, wrong on the next hospital's data. Aggregate metrics hide who it fails for.

Example Control: Subgroup acceptance criteria in the spec.

5 Data governance

Provenance, consent, annotation, leakage between train/test.

Example Control: Versioned data; documented curation.

6 Uncontrolled change

A retrain is a new version of a certified device.

Example Control: Change request, impact assessment, re-V&V.

Put your own tool through this

Do it for both artefacts — the FLAIR-threshold viewer and the U-net.

- | | | |
|----------|---|---|
| A | Intended purpose & qualification | Write the one-sentence intended purpose for your viewer and for your classifier; run the MDSW flow-chart. |
| B | Classification under rule 11 | Place both on the MDCG/IMDRF matrix; argue a class and defend it. |
| C | Mini risk analysis | Five hazards as full chains with SxO ratings for your u-net . Controls in priority order — at least two of them design or protective. |
| D | Evidence plan | For one requirement, write a verification test and define one external test: which site, which subgroups, which thresholds. |
| E | Dependencies & change | List your SOUP; decide what a retrain triggers in the lifecycle. |

Hand back a mini risk file and a classification rationale.

Intended purpose & qualification

Fill this in for both artefacts. The claim makes the device — write the purpose, then the reasoning behind your verdict.

FLAIR-threshold viewer

1 · Intended purpose — one sentence

“..... is intended to for in , based on”

2 · Qualification flow-chart (MDCG 2019-11)

Q1 Is it software, and does it run standalone?

Yes / No

Q2 More than store, archive, compress or search?

Yes / No

Q3 Is the action for an individual patient's benefit?

Yes / No

Q4 Is the purpose medical under Art. 2(1) MDR?

Yes / No

Verdict: MDSW / not a medical device →

3 · Justification — why that verdict?

Which answer above decided it, and which words make the claim medical?

U-net classifier

1 · Intended purpose — one sentence

“..... is intended to for in , based on”

2 · Qualification flow-chart (MDCG 2019-11)

Q1 Is it software, and does it run standalone?

Yes / No

Q2 More than store, archive, compress or search?

Yes / No

Q3 Is the action for an individual patient's benefit?

Yes / No

Q4 Is the purpose medical under Art. 2(1) MDR?

Yes / No

Verdict: MDSW / not a medical device →

3 · Justification — why that verdict?

Which answer above decided it, and which words make the claim medical?

Medical purpose, MDR Art. 2(1) — diagnosis, prevention, monitoring, prediction, prognosis, treatment or alleviation of disease; diagnosis, monitoring, treatment, alleviation of or compensation for an injury or disability; investigation, replacement or modification of the anatomy or of a physiological or pathological process or state.

Classification under rule 11

Place both artefacts on the matrix, state the class, then write the argument that defends it.

Write V (viewer) and U (U-net) into one cell each

	Non-serious	Serious	Critical
Treat or diagnose <i>IMDRF IV / III / II</i>			
Drive clinical management <i>IMDRF III / II / I</i>			
Inform clinical management <i>IMDRF II / I / I</i>			

Significance of the information (rows) × state of the healthcare situation (columns) — MDCG 2019-11 rev. 1, Annex III.

- 1 Does the output drive clinical management, or only inform it? Who acts on it, and can they check it?
- 2 Which escalation bites: death or irreversible deterioration (III), or serious deterioration / surgery (IIb)?
- 3 If you argue IIa, write the sentence a reviewer would use against you — and your answer to it.

1 • Your call

FLAIR viewer: I / IIa / IIb / III

U-net: I / IIa / IIb / III

Same class for both? If not, why not?

2 • Rule text you rely on

Rule 11

3 • Justification for the class

Why this cell on the matrix

Why not one class higher

Why not one class lower

Mini risk analysis — the five chains

Five hazards for your U-net, each written as a full chain. A hazard on its own is not a risk.

#	Hazard	Sequence of events	Hazardous situation	Harm	S	O	S×O
1							
2							
3							
4							
5							

Severity 1–5 · Occurrence 1–5. For software you cannot estimate a failure probability — justify O from exposure and detectability, or set it to worst case and say so.

Risk controls, in priority order

One control per chain. At least two of the five must be design or protective — not a line in the IFU.

1

Design it out — inherently safe design

2

Guard it — protective measure or alarm

3

Warn — information for safety / IFU

#	Risk control measure	Type (design / protective / info)	Residual S×O	How the control is verified	New risk introduced?
1					
2					
3					
4					
5					

A control you cannot verify is not a control. If residual risk is still unacceptable, go back up the priority order — do not add a second warning.

Evidence plan — verification of one requirement

Pick one requirement. Trace it all the way to a record. Verification asks: did we build it right?



1 · Requirement, as written in your spec

REQ-..... : The software shall (one testable statement, no “should”, no “adequate”)

2 · Verification test — what you actually run

Input data Steps Expected output

3 · Pass / fail criterion — a number, not an adjective

Pass if $\geq / \leq$ measured over cases. Who signs it off?

4 · Evidence record — where it lives

Document / ID Tool & version Traces to hazard no. and risk control no.

Sanity check — can you draw an unbroken line from intended purpose → requirement → test → result → the risk control it discharges?
If the criterion contains “reasonable”, “robust” or “acceptable”, it is not a criterion. Replace it with a threshold you would report to a notified body.

Evidence plan — the external test

Validation asks: did we build the right thing? Define the set before you see the result.

1 • External test set — provenance

Site(s) Scanner vendor / field strength Acquisition dates n =
..... Inclusion / exclusion

2 • Primary endpoint & acceptance threshold

Endpoint Acceptance $\geq / \leq$ with 95% CI lower bound
Reference standard

3 • Subgroups you will report separately

Subgroup	n	Why it matters	Threshold

e.g. lesion size, tumour type, scanner vendor, site, age band, prior surgery.

Independence — the set was never used for training, tuning or model selection. Who holds it, and when was it locked?
Pre-specification — endpoint, subgroups and thresholds written down before the run. Which document, which version?
Coverage — name one population or scanner you have NOT tested, and show where the IFU states that limitation.

Dependencies & change

List your SOUP, then decide what a retrain triggers in the lifecycle.

SOUP component / library	Version	What it does in your pipeline	Anomaly list checked	What happens if it fails

Every SOUP entry needs a version, a purpose and a published anomaly list you have actually reviewed — that is the SBOM baseline.

1 • What triggers a retrain?

New site or scanner Performance drift beyond New data volume Complaint / PMS signal Other

2 • What does a retrain trigger?

Re-verify Re-validate on external set Re-assess risk file Re-classify Significant change notification? Yes / No — on what basis?